

THREAT ADVISORY



ATTACK REPORT

**Recent Lazarus campaign leveraged
Crypto App to spread AppleJeus
malware**

Date of Publication

December 6, 2022

Last Updated Date

December 7, 2022

Admiralty Code

A1

TA Number

TA2022282

Summary

First appeared: June 2022

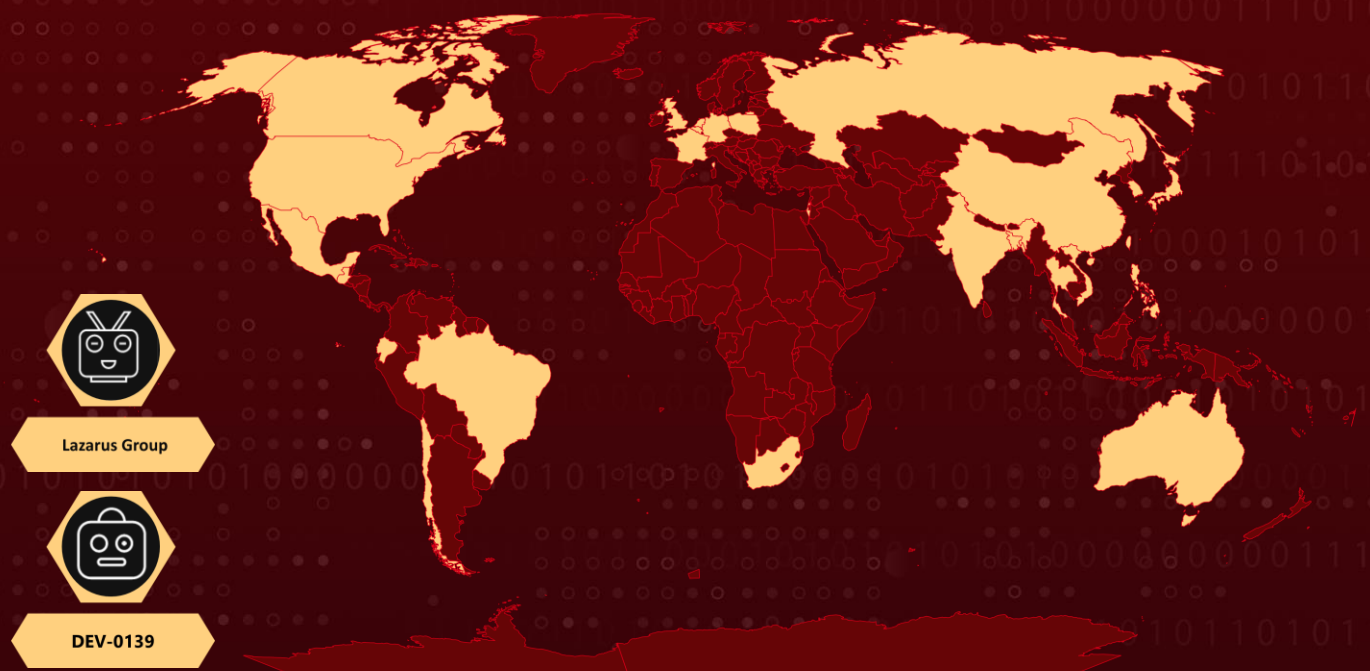
Threat Actors: Lazarus Group, DEV-0139

Attack Region: Australia, Bangladesh, Belgium, Brazil, Canada, Chile, China, Ecuador, France, Germany, Guatemala, Hong Kong, India, Israel, Japan, Mexico, Netherlands, Philippines, Poland, Russia, South Africa, South Korea, Taiwan, Thailand, UK, USA, Vietnam

Attack Industries: Aerospace, Defense, Energy, Engineering, Financial, Government, Media, Shipping and Logistics, Technology, and Cryptocurrency.

Attack: steals the victim's private keys and exhausts crypto assets

Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Attack Details

#1

The Lazarus Group threat actor was noticed employing fake cryptocurrency apps as a ruse to transmit a previously unidentified version of the AppleJeus malware masquerading as malicious Microsoft Office documents. AppleJeus was initially discovered in 2018 and was primarily intended to collect information about the infected system and download shellcode from a command-and-control (C2) server.

#2

The latest campaign began in June 2022 and lasted until at least October 2022. The threat actors employed the "bloxholder[.]com" domain in this operation, which is a clone of an automated cryptocurrency trading platform. The attackers modified their approach to transmitting malware via Microsoft Office documents rather than the MSI installer.

#3

A notable feature in recent AppleJeus samples is that all strings and API calls are now obfuscated using a customized algorithm, making them less detectable by monitoring software. It was noticed, the DEV-0139 threat actor also targeted attacks against the cryptocurrency industry.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0005</u> Defense Evasion
<u>TA0007</u> Discovery	<u>TA0008</u> Lateral Movement	<u>TA0009</u> Collection	<u>TA0011</u> Command and Control
<u>TA0040</u> Impact	<u>T1574</u> Hijack Execution Flow	<u>T1566</u> Phishing	<u>T1573</u> Encrypted Channel
<u>T1559</u> Inter-Process Communication	<u>T1059</u> Command and Scripting Interpreter	<u>T1496</u> Resource Hijacking	<u>T1027</u> Obfuscated Files or Information
<u>T1082</u> System Information Discovery	<u>T1113</u> Screen Capture		

Indicator of Compromise (IOC)

TYPE	VALUE
MD5	245bb604621cea7962668325995bca7c 18644822140eda7493bd75ba1e1f235d 76111d9780b2d0b5adee61cf752d937e 51871504c1d5c09ade5e2a1e6e98c37a
SHA1	cc5544eff3e5b9cf20d8cf2291147596d4346dbe b801643e2d817931e6aa36e6bf24d1c42e9b8fdc 5b03294b72c0caa5fb20e7817002c600645eb475 ae34fa6c6baf77390fb3ff683d880cde14bf893d
SHA256	17e6189c19dedea678969e042c64de2a51dd9fba69ff521571d63f d92e48601b,abca3253c003af67113f83df2242a7078d5224870b6 19489015e4fde060acad0,a2d3c41e6812044573a939a51a22d65 9ec32aea00c26c1a2fdf7466f5c7e1ee9,2e8d2525a523b0a47a22 a1e9cc9219d6526840d8b819d40d24046b17db8ea3fb,82e67114 d632795edf29ce1d50a4c1c444846d9e16cd121ce26e63c8dc4a1 62

TYPE	VALUE
SHA256	90b0a4c9fe8fd0084a5d50ed781c7c8908f6ade44e5654acffea922e281c6b33,efaf52549ffcc8a16373a8f7f0bddebabc3edc17f71b0158bbaf89c1b29a6043,a0db8f8f13a27df1eacbc01505f311f6b14cf9b84fbc7e84cb764a13f001dbbb,9352625b3e6a3c998e328e11ad43efb5602fe669aed9c9388af5f55fadfedc78,fe948451df90df80c8028b969bf89ecbf501401e7879805667c134080976ce2e,e5980e18319027f0c28cd2f581e75e755a0dace72f10748852ba5f63a0c99487,eee4e3612af96b694e28e3794c4ee4af2579768e8ec6b21daf71acfc6e22d52b,82d6b2e14763f398d2a559d3f7fbf2f7a3c7f9001c8dcdf4543d4ff0b97a8785,636813038ba5c9755aa881ae62e2911df3b8f84ad1d2ff682e325e00d24d4a74,295c20d0f0a03fd8230098fade0af910b2c56e9e5700d4a3344d10c106a6ae2a,479cc0a490ffa98652683796c5cef12f3e6380107aac83321a9705048b801b54,4c5611d63fd78a2de9591d7b4d70c574d1f534a2aec86bb70bd49e60fafd54ea
Domains	strainservice[.]com bloxholder[.]com rebelthumb[.]net wirexpro[.]com oilycargo[.]com teloo[.]io
URL	hxxps://od.lk/d/d021d412be456a6f78a0052a1f0e3557dcfa14bf25f9d0f1d0d2d7dcdac86c73/Background[.]png
IP Address	198.54.115[.]248

References

<https://www.volexity.com/blog/2022/12/01/buyer-beware-fake-cryptocurrency-applications-serving-as-front-for-applejeus-malware/>

<https://www.microsoft.com/en-us/security/blog/2022/12/06/dev-0139-launches-targeted-attacks-against-the-cryptocurrency-industry/>

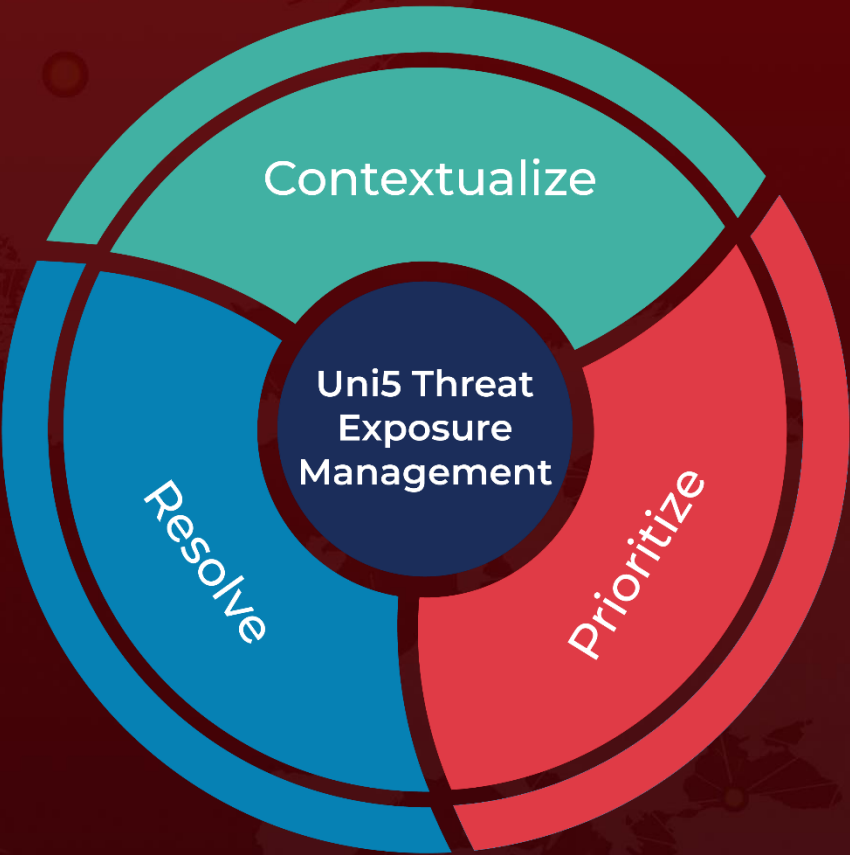
<https://thehackernews.com/2022/12/north-korean-hackers-spread-applejeus.html>

<https://attack.mitre.org/groups/G0032/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
December 6, 2022 • 4:02 AM

